Open Budget Data Retention and Disposal Policy

Version 1.0 · Effective Nov 2, 2026 · Owner Jacob Shade

Purpose and scope

Open Budget keeps consumer financial data only as long as it is needed to show it to the person who connected it, and then deletes it so it cannot be recovered.

This policy covers all data Open Budget stores: data received from Plaid, Google sign-in data, sign-in security data, secrets, logs and backups, on the host and on any storage media that holds them. It supports the Information Security Policy and the Privacy Policy. The Security Owner, Jacob Shade, carries out every procedure here and records each one in the evidence log of the Information Security Policy.

Each rule is marked **Automatic** (the app does it), **Manual** (the Security Owner does it on the stated trigger) or **Planned** (not yet in place).

Principles

- **Minimum collection:** only the data listed in the schedule below is stored. Bank credentials, full account numbers and routing numbers are never received.
- **Tied to consent:** financial data is kept only while the bank connection that produced it is active. Removing the connection is the user's withdrawal of consent, and the data goes with it.
- **No archive:** Open Budget does not keep historical copies of financial data after deletion, except in the rolling encrypted backups described below, which age out.
- **Encrypted until destroyed:** every copy of Restricted data stays AES-256 encrypted from the moment it is stored until it is disposed of.

Retention schedule

Data	Kept until	How it is deleted	Type
Plaid access token and item ID	The bank connection is removed	Token revoked at Plaid (`/item/remove`), then the row is deleted	Automatic, on removal
Accounts and balances	Their bank connection is removed	Deleted with the connection (database cascade)	Automatic, on removal
Transactions	Their bank connection is removed, or Plaid reports them removed	Deleted with the connection, or during the next sync	Automatic

Data	Kept until	How it is deleted	Type
Bank connections inactive for 12 months (no successful sync)	Found in the quarterly review	Removed in the app, which revokes and deletes as above	Manual, quarterly
Google profile (account ID, email, name, picture link)	The user asks for deletion or is removed from `ALLOWED_EMAILS`	User record deleted	Manual, within 30 days
Authenticator secret and recovery codes	The user record is deleted, or MFA is re-enrolled	Deleted with the user (cascade); re-enrollment replaces them	Automatic
Verified sessions	7 days, or sign-out	Sign-out deletes immediately; expired sessions are purged at the next sign-in	Automatic
Unfinished sign-ins (pending sessions, OAuth state)	10 minutes	Rejected after expiry; purged at the next sign-in	Automatic
Operational logs	90 days	Rotated by the log driver	Planned (see open items)
Encrypted database backups	4 weeks (4 weekly copies)	Oldest copy deleted when a new one is made	Planned (R12)
Secrets (database key, Plaid and Google client secrets)	Replaced at rotation, or the service is shut down	Old value deleted from `.env` and the password manager once the new one works	Manual
Source code	Indefinitely	Contains no consumer data or secrets	Not applicable

Plaid's own retention of data it collects is governed by the Plaid End User Privacy Policy, not this policy.

Deletion procedures

Removing a bank connection (Automatic)

1. The user clicks **Remove** next to the bank in Open Budget.
2. The app calls Plaid's `/item/remove`, which permanently revokes the access token. If Plaid already reports the item as gone, the app continues.
3. The app deletes the connection; its accounts and transactions are deleted with it by database cascade.

If the Plaid call fails for any other reason, nothing is deleted locally and the user sees the error, so a token is never left active at Plaid without a record of it.

Deleting a user's data on request (Manual, within 30 days)

Bank connections are shared by all approved users of an instance, not owned by one user. A deletion request is handled as follows:

1. Confirm the request comes from the user's own Google account email.
2. Remove every bank connection that user linked, using **Remove** in the app.
3. Remove the email from `ALLOWED_EMAILS` and restart the app.
4. Delete the user record, which also deletes their authenticator secret, recovery codes and sessions:

   ```
   docker compose stop
   docker compose cp app:/data/budget.db ./budget.db
   sqlcipher budget.db <<SQL
   PRAGMA key = "x'$(grep ^DATABASE_KEY= backend/.env | cut -d= -f2)'";
   PRAGMA foreign_keys = ON;
   DELETE FROM users WHERE email = 'user@example.com';
   VACUUM;
   SQL
   docker compose cp ./budget.db app:/data/budget.db && shred -u budget.db && docker
           compose start
   ```

5. Tell the user it is done, and record the request and completion date in the evidence log.

Quarterly retention review (Manual)

As part of the quarterly review in the Information Security Policy:

1. List bank connections and their last sync date in the app. Remove any with no successful sync in 12 months, and any the owner no longer uses.
2. Compare the Items in the Plaid dashboard with the connections in the app. Remove any Item at Plaid that the app doesn't know about.
3. Compare `ALLOWED_EMAILS` with the users in the database, and delete any user no longer allowed (procedure above).
4. Confirm backups older than 4 weeks have been deleted.
5. Run `VACUUM` on the database during a maintenance stop, so pages freed by deletions are rewritten (see Disposal below).

Disposal

Deleted data must not be recoverable from the database file, backups, logs or the hardware.

- **Inside the database:** SQLite may leave deleted rows in freed pages until they are reused. In Open Budget those pages are still AES-256 encrypted, so they are unreadable without the key. The

quarterly `VACUUM` rewrites the file without them. Turning on `PRAGMA secure_delete` so freed pages are zeroed immediately is a planned improvement.

- **Temporary copies:** any decrypted or copied database file used for maintenance is deleted with `shred -u` as soon as the task is done. Decrypted data is never exported to CSV, spreadsheets or other files.
- **Backups:** expired backup files are deleted from the backup storage. Because every backup is encrypted with the database key, rotating the key after a suspected exposure also makes older backups unreadable once the old key is destroyed.
- **Secrets:** after rotation, the old secret is removed from `.env`, the password manager and any notes, and revoked in the Plaid or Google dashboard where possible.
- **Hardware:** before a disk or computer that held Open Budget data is sold, returned, recycled or repaired by others, first remove all bank connections (which revokes the tokens at Plaid), then either securely erase the drive (the drive's built-in secure erase or a full overwrite) or physically destroy it. With full-disk encryption, destroying the disk key is an acceptable alternative.
- **Shutting down the service:** remove every bank connection in the app, confirm no Items remain in the Plaid dashboard, delete the Docker volume (`docker compose down -v`) and all backups, then destroy the database key.

Legal holds and exceptions

If a law, court order or investigation requires data to be kept, the Security Owner suspends deletion of only the affected data, records the reason and scope in the evidence log, and resumes the normal schedule when the requirement ends. No other exceptions are allowed.

Open items

- [ ] Configure Docker log rotation and 90-day retention (today the container's log has no size limit and is lost only when the container is recreated)
- [ ] Set up weekly encrypted off-host backups with 4-week retention (R12)
- [ ] Turn on `PRAGMA secure_delete` so deleted rows are zeroed immediately
- [ ] Purge expired sessions on a schedule, not only at the next sign-in

Review

This policy is reviewed yearly with the Information Security Policy, and whenever a new type of data is stored or a new place holds data (a new host, backup service or vendor).